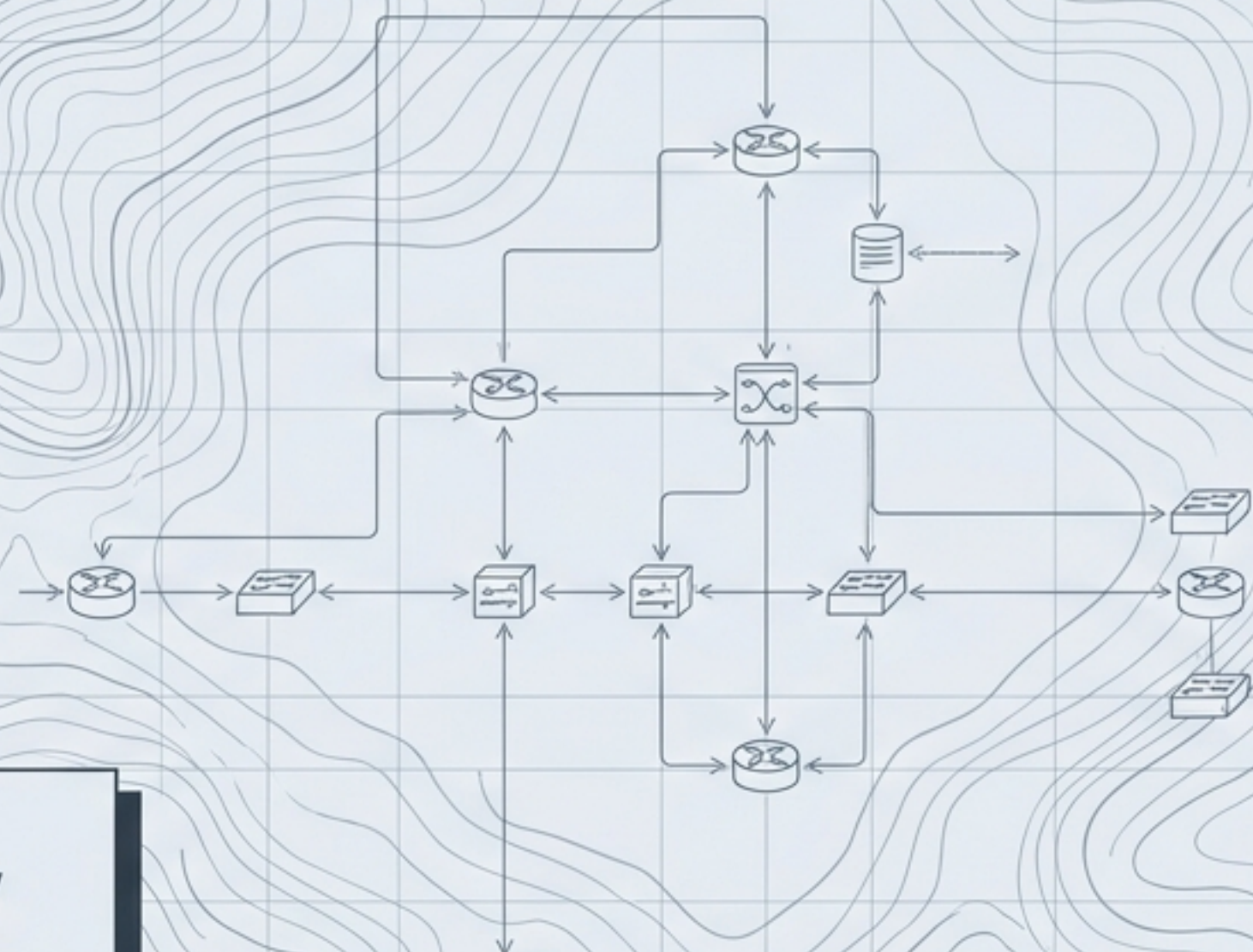


Presentado por Carlos Noboa

Cartografía Digital y Escaneo de Redes

De la inteligencia de fuentes abiertas a la manipulación profunda de paquetes TCP/UDP.



El Paradigma del Hacking Ético

En un escenario real, la eficacia de un ataque depende enteramente de la precisión del mapa construido previamente.

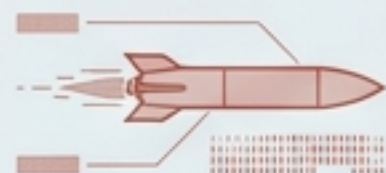
90% PREPARACIÓN

Elaboración de un perfil detallado de la entidad o persona. Maximiza las probabilidades de éxito.



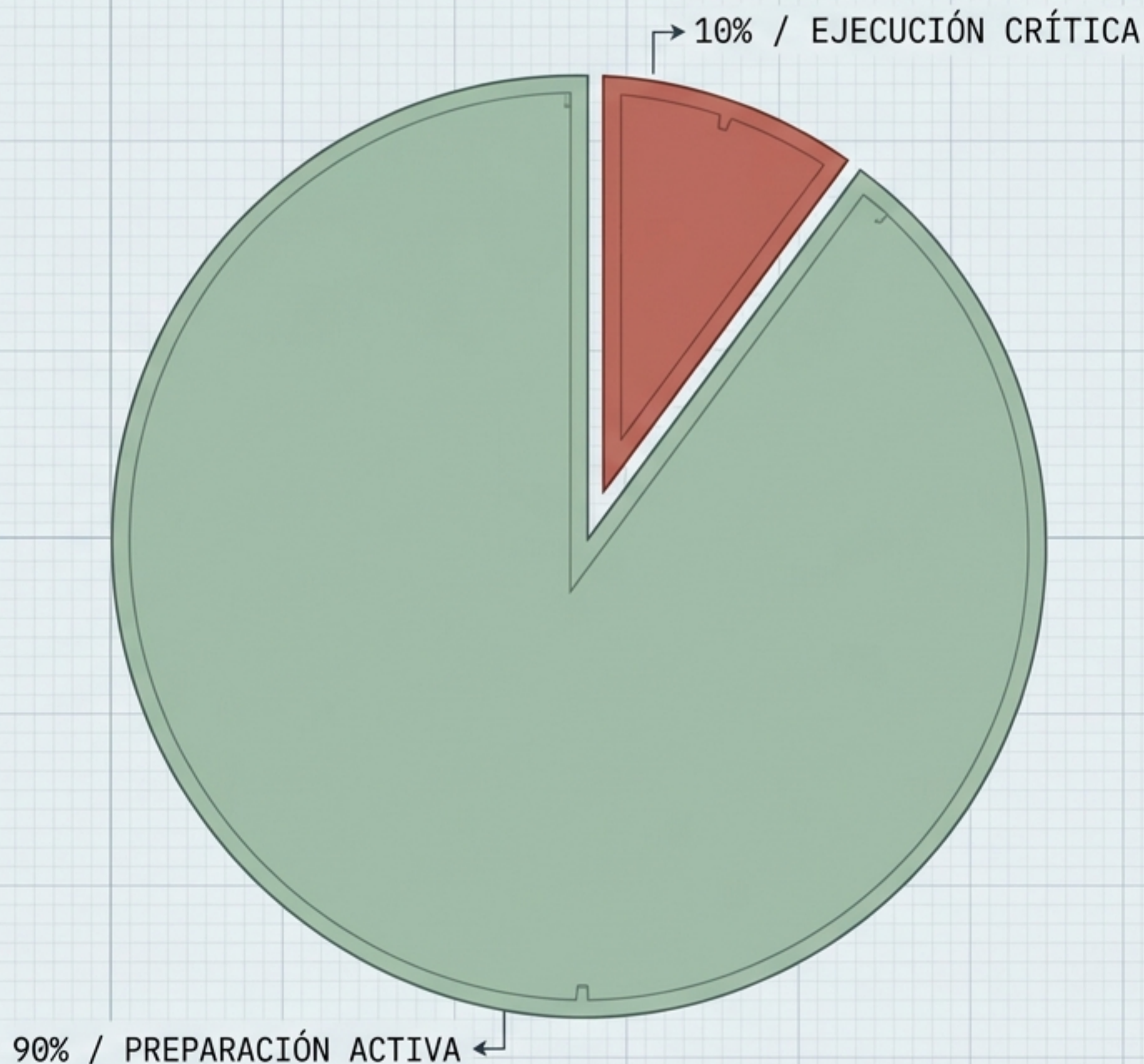
10% EJECUCIÓN

El lanzamiento del ataque técnico en sí.



OBJETIVO DEFENSIVO

Detectar deficiencias y fugas expuestas antes de que sean explotadas.



Mapeando el Factor Humano

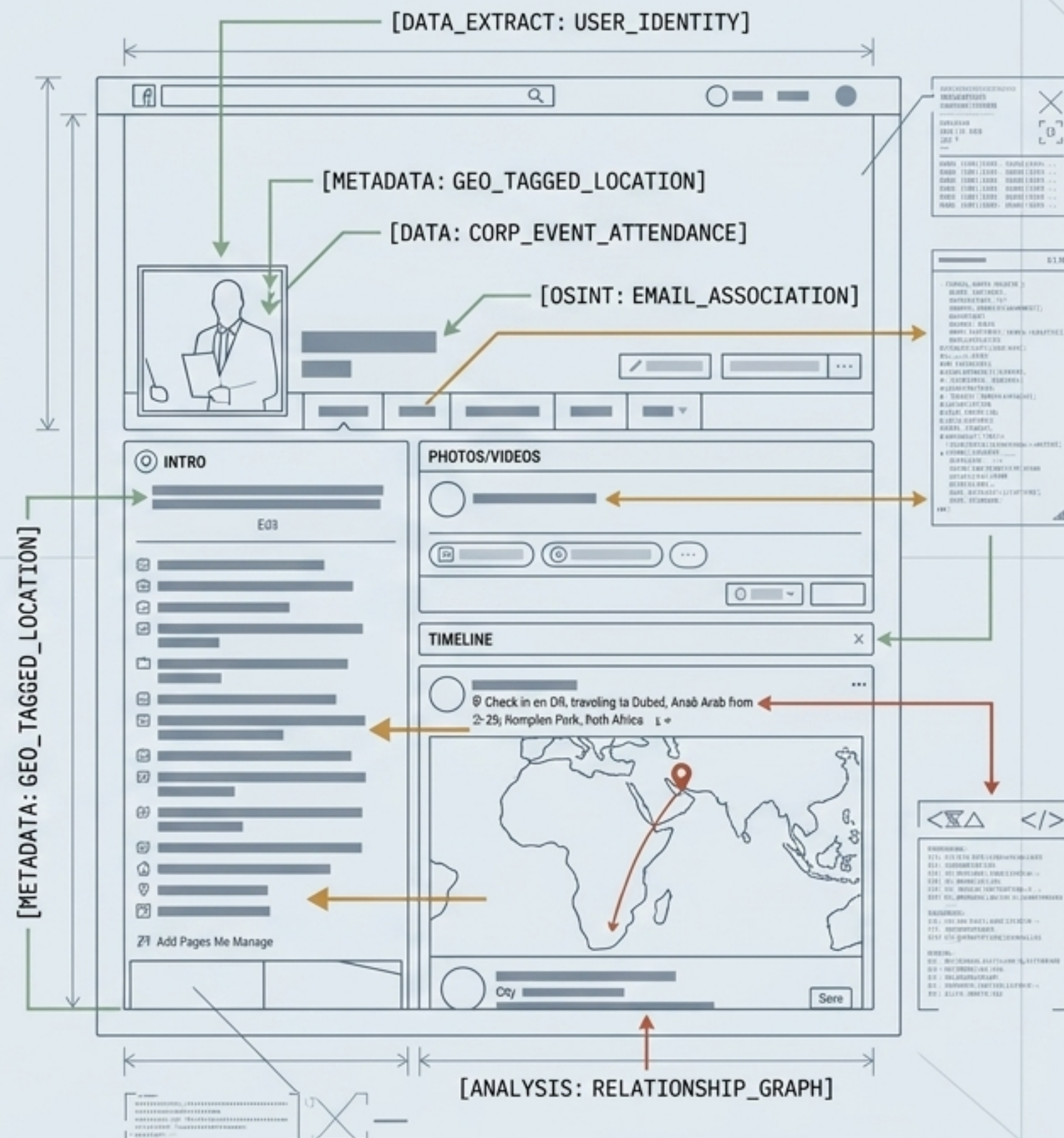
El auge de las redes sociales permite obtener información crítica de forma simple y anónima. Estas fuentes conforman el vector principal para ataques de ingeniería social.

VECTORES DE EXTRACCIÓN

Empleados, emails, eventos corporativos, tecnologías utilizadas.

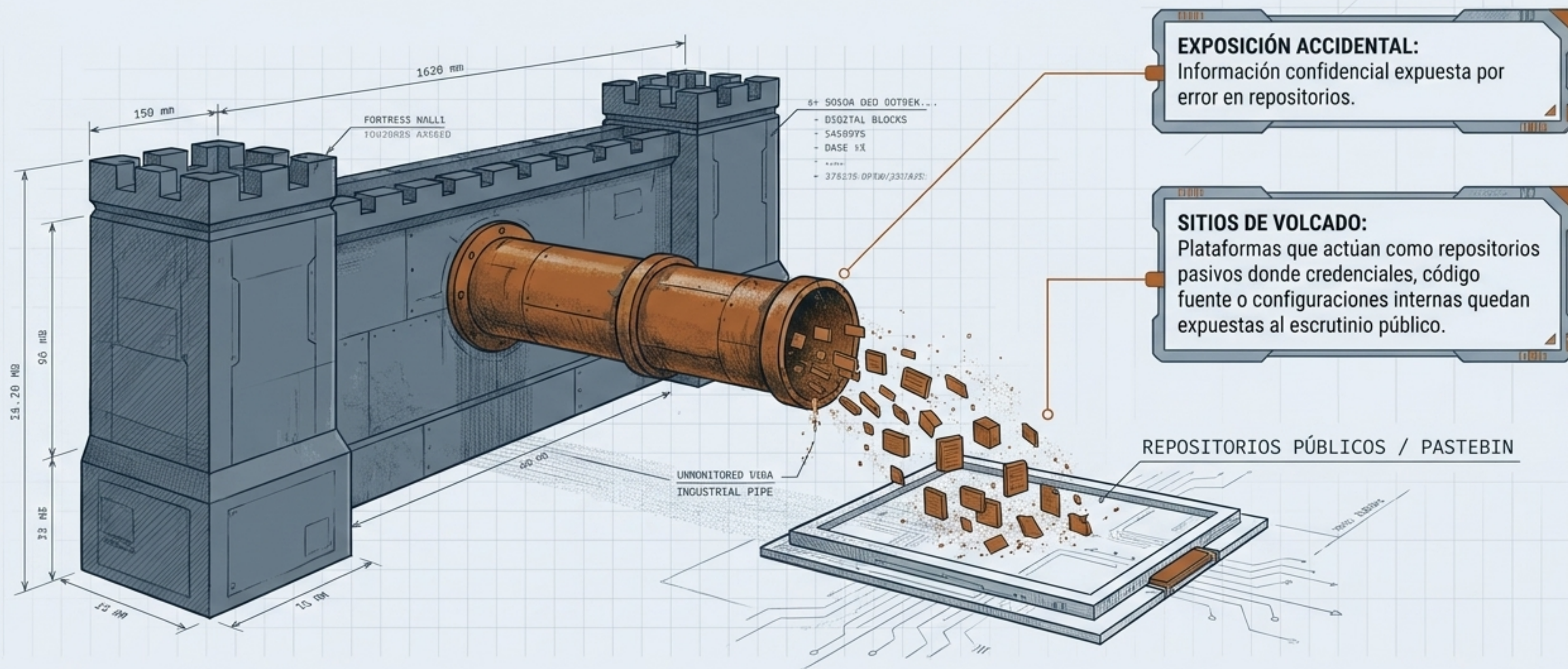
HERRAMIENTAS ESPECIALIZADAS

Plataformas como Tinfoleak (análisis de Twitter) o Raven permiten automatizar la recolección de inteligencia.



Fugas en el Perímetro Externo

Un alto nivel de ciberseguridad corporativa a menudo es eludido por fallos derivados directamente del error humano.



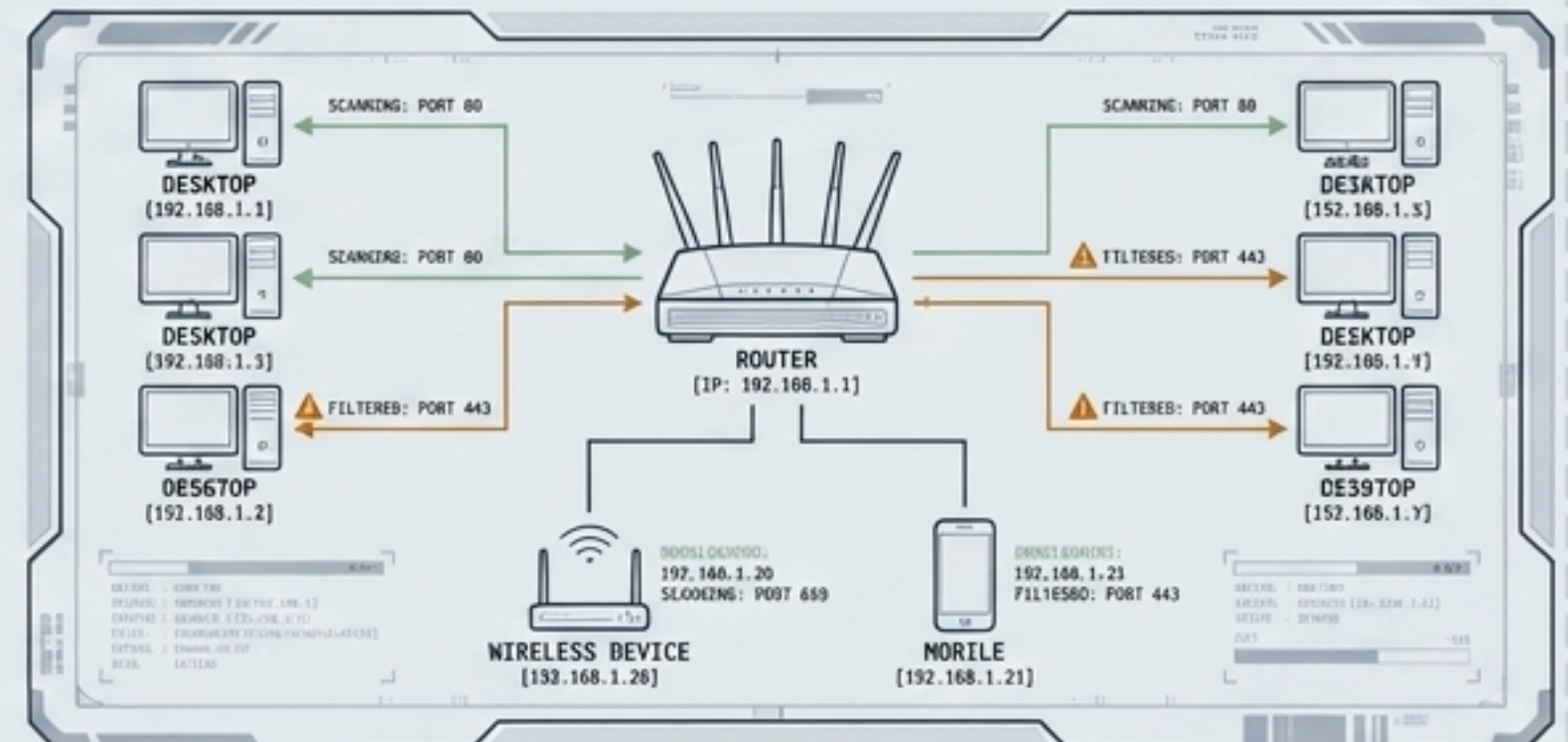
Cruzando la Línea: De Pasivo a Activo

Transición hacia la cartografía técnica. Un escáner de red identifica hosts activos, direcciones IP y servicios en ejecución. Este proceso abandona el anonimato y se vuelve directamente intrusivo.

EL PERÍMETRO

OSINT (Recolección Pasiva)

Network Scans
(Exploración Activa e Intrusiva)



Nmap: El Estándar de Exploración

Herramienta de código abierto diseñada para analizar rápidamente grandes redes o equipos individuales.



01. Auditorías

Ejecución de pentesting y análisis de seguridad ofensiva.



02. Inventariado

Mapeo de la red por administradores de sistemas para control de activos.



03. Monitorización

Planificación de actualizaciones y verificación continua de uptime.



Tomando el Pulso: El Barrido de Ping

Un ping sweep determina qué direcciones IP dentro de un rango están activas, enviando paquetes a toda la red.

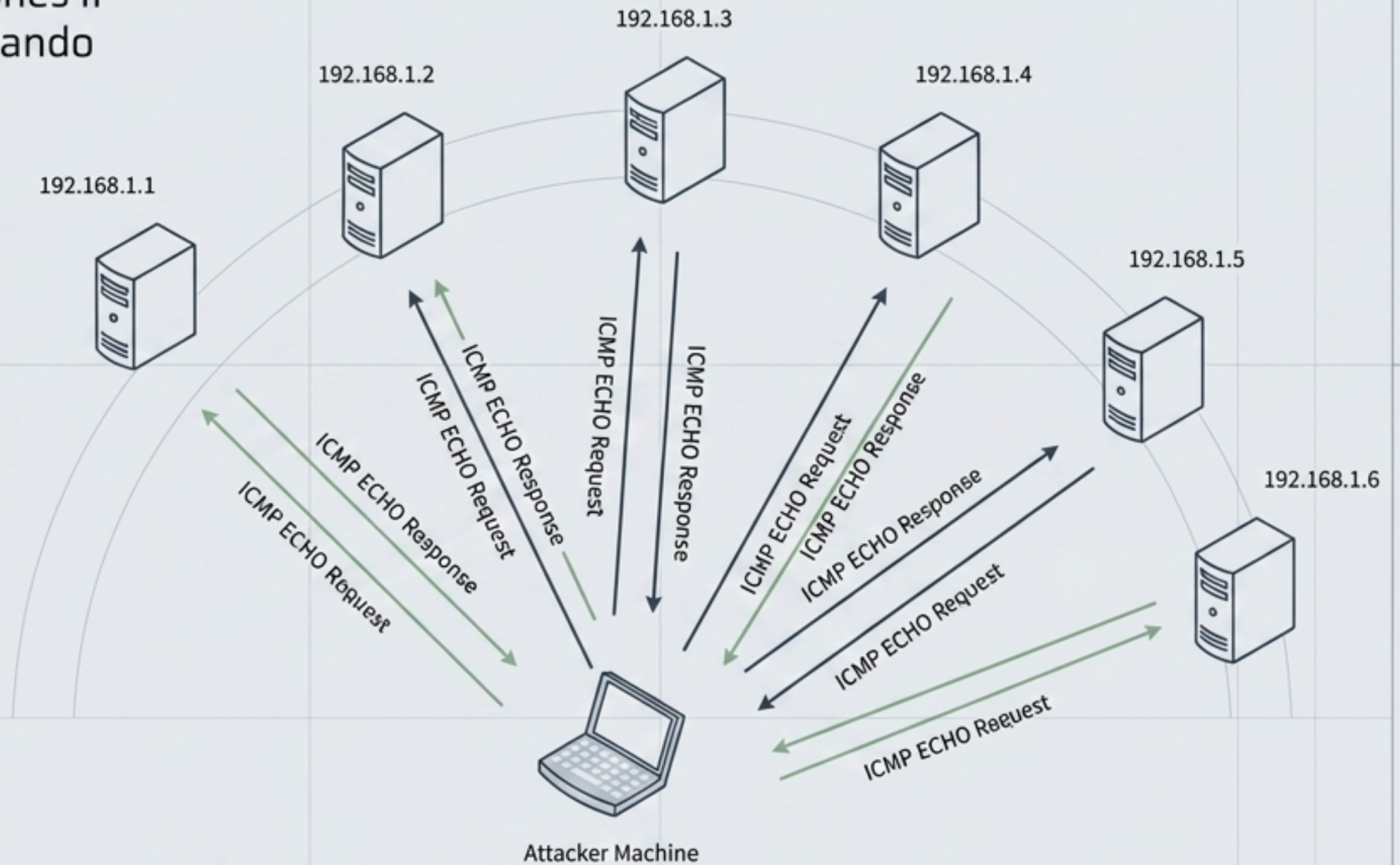
PROTOCOLO: ICMP (RFC 792)

MECÁNICA:

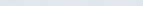
ICMP ECHO Request -> ICMP ECHO Response

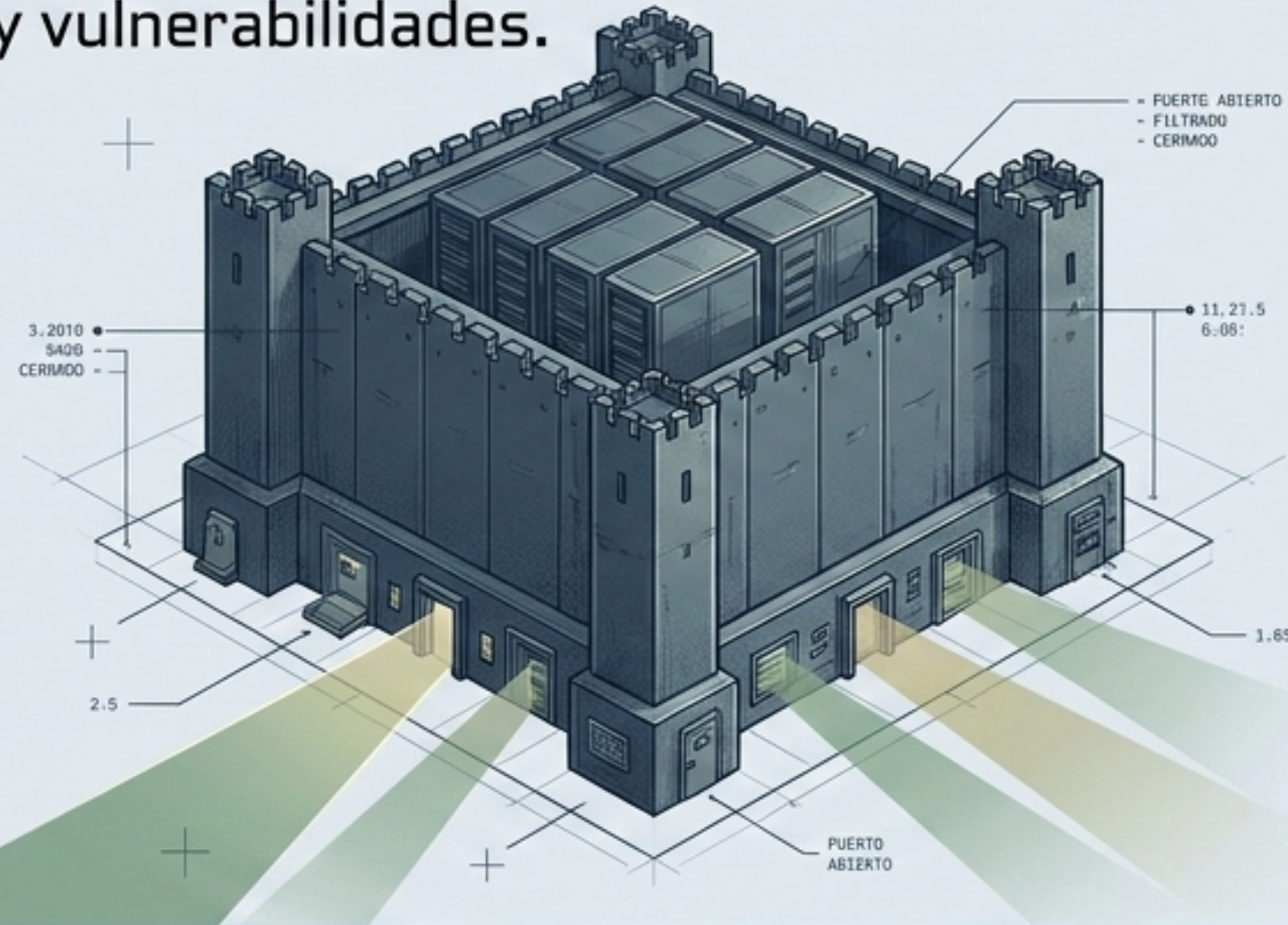
COMANDO NMAP:

`nmap -sn <hosts>`



El Objetivo del Escaneo de Puertos

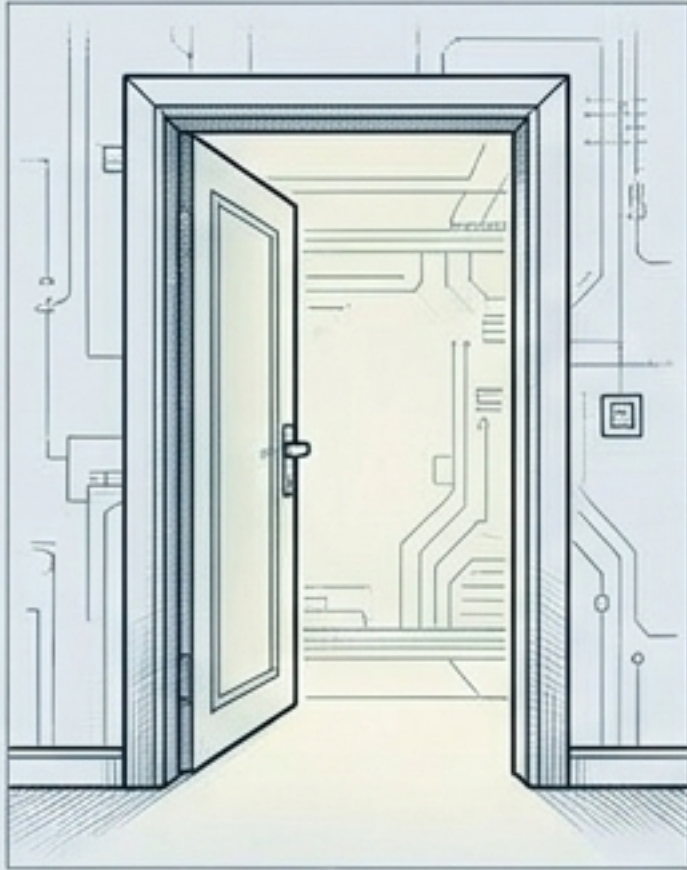
Identificar los servicios expuestos por un activo para mapear la superficie total de exposición a ataques y vulnerabilidades. 



Insight: Incluso un servidor web aparentemente bastionado y seguro puede tener servicios secundarios expuestos que comprometan la seguridad de toda la máquina.

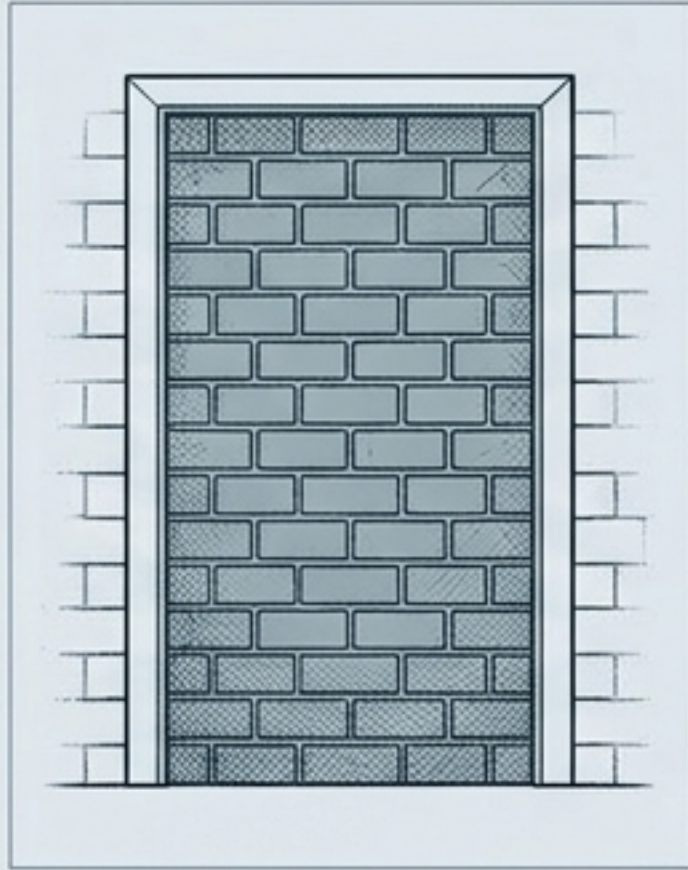
La Psicología del Puerto: Los 4 Estados

ABIERTO



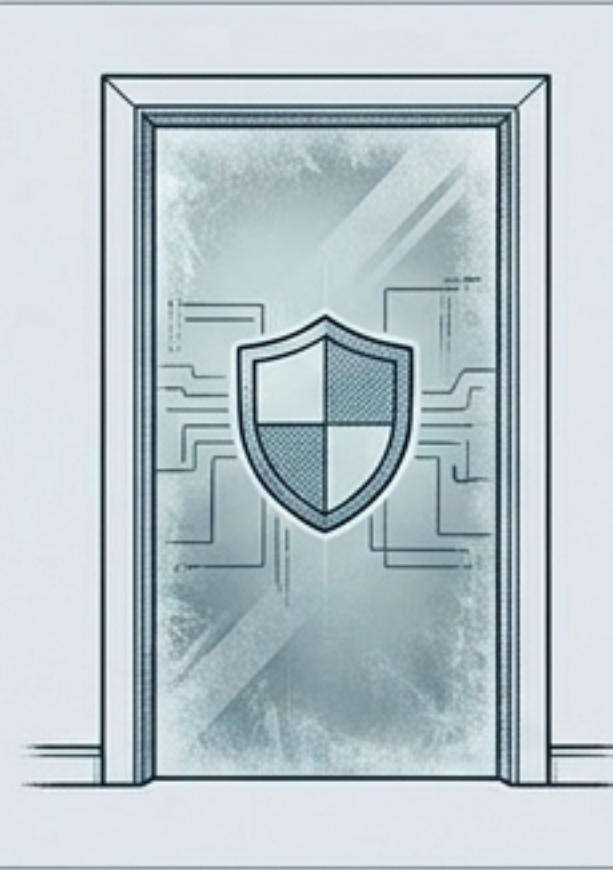
Una aplicación está escuchando/esperando conexiones activamente.

CERRADO



El host responde, pero no hay ninguna aplicación escuchando en ese puerto.

FILTRADO



Un firewall o filtro de red bloquea el acceso. Nmap no puede saber si está abierto o cerrado.

NO FILTRADO



Responde a las sondas, pero la herramienta no puede determinar su estado final (común en escaneos ACK).

Matriz de Diagnóstico: Escaneo TCP vs UDP

■ TCP Scan

Frecuencia:

El estándar más común en la exploración.

Mecánica:

Basado en conexiones persistentes y apretones de manos (*handshakes*).

Rendimiento:

Rápido y altamente determinista.

■ UDP Scan

Frecuencia:

Frecuentemente ignorado (un error crítico en auditorías).

Mecánica:

Protocolo no orientado a conexión. Envía un REQUEST y evalúa.

Rendimiento:

Lento. Depende de *timeouts* del servidor. Si no hay respuesta, no hay certeza de si está cerrado o filtrado.

Superficie de Ataque I: Acceso Remoto y Web

Acceso Remoto y Control

21

ftp

22

ssh

23

telnet

3389

rdp

5900

vnc

1723

pptp

Servicios Web

80

http

443

https

8080

http-proxy

Superficie de Ataque II: Correo e Infraestructura

Comunicaciones de Correo

25

smtp

110

pop3

143

imap

993

imaps

995

pop3s

Infraestructura y Bases de Datos

53

dns

111

rpcbind

135

msrpc

139

netbios

445

microsoft-ds

3306

mysql

Los Servicios Silenciosos: Puertos UDP

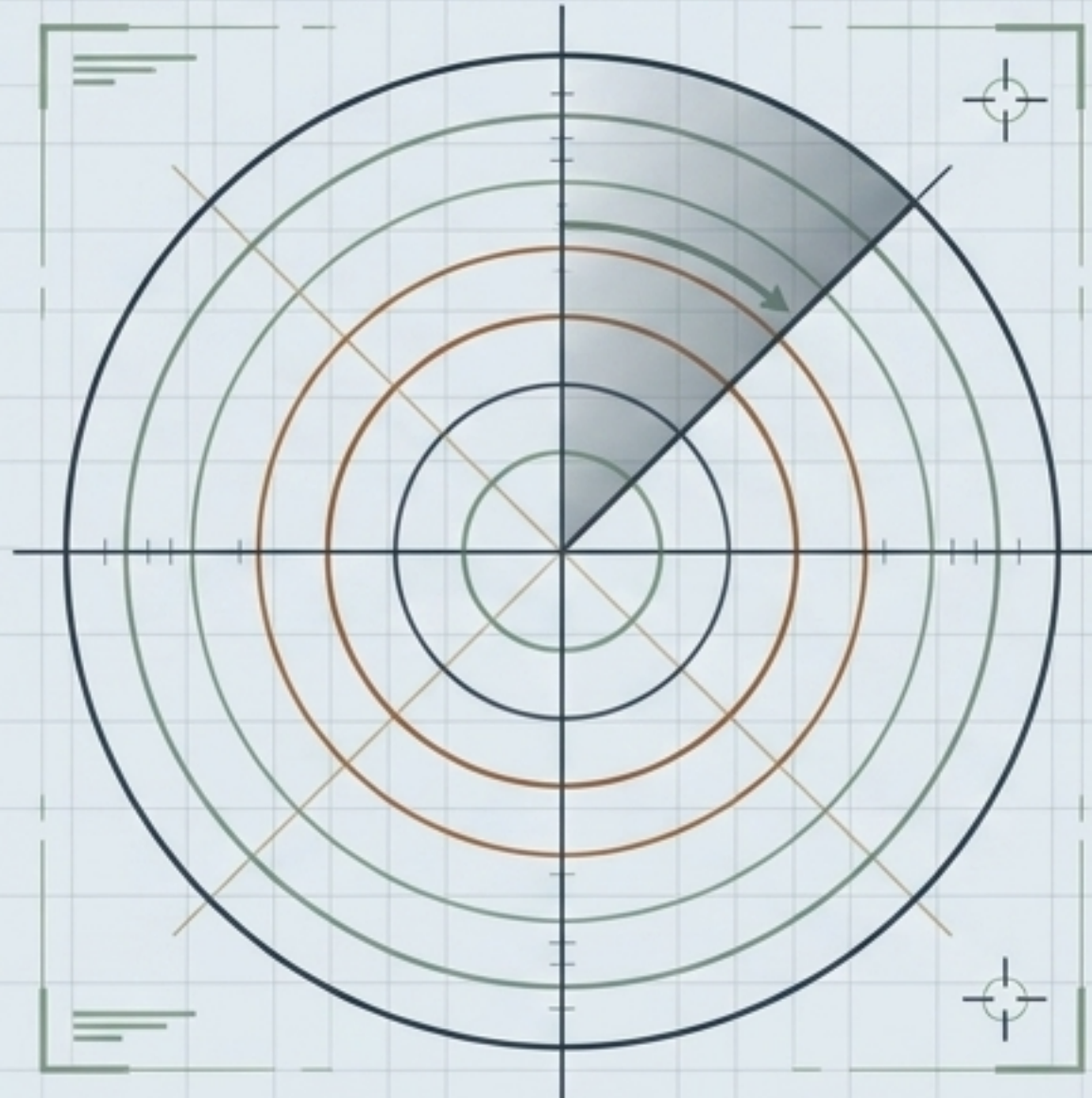
Ignorar los puertos UDP deja un punto ciego masivo en la auditoría. Muchos servicios críticos operan en silencio, sin conexiones persistentes.

67 / 68

DHCP (Asignación de IPs)

161 / 162

SNMP (Monitorización de red)



53

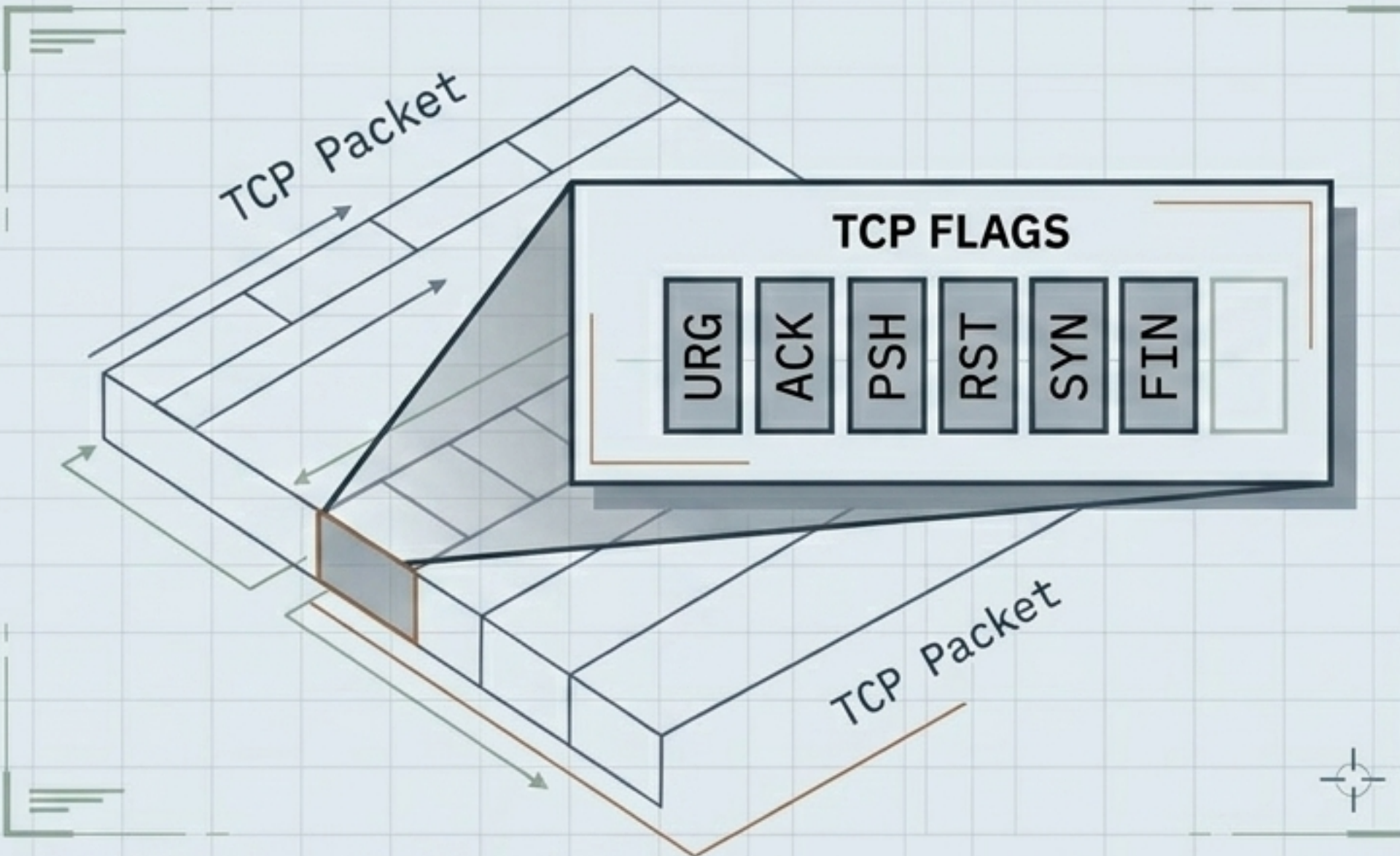
DNS (Resolución de nombres)

88

Xbox Live (Servicios de juego/entretenimiento)

El Arsenal de Nmap: Manipulación de Paquetes

Nmap no solo llama a la puerta; manipula las banderas (flags) de los paquetes TCP para forzar reacciones específicas del servidor o evadir defensas.



TCP Connect

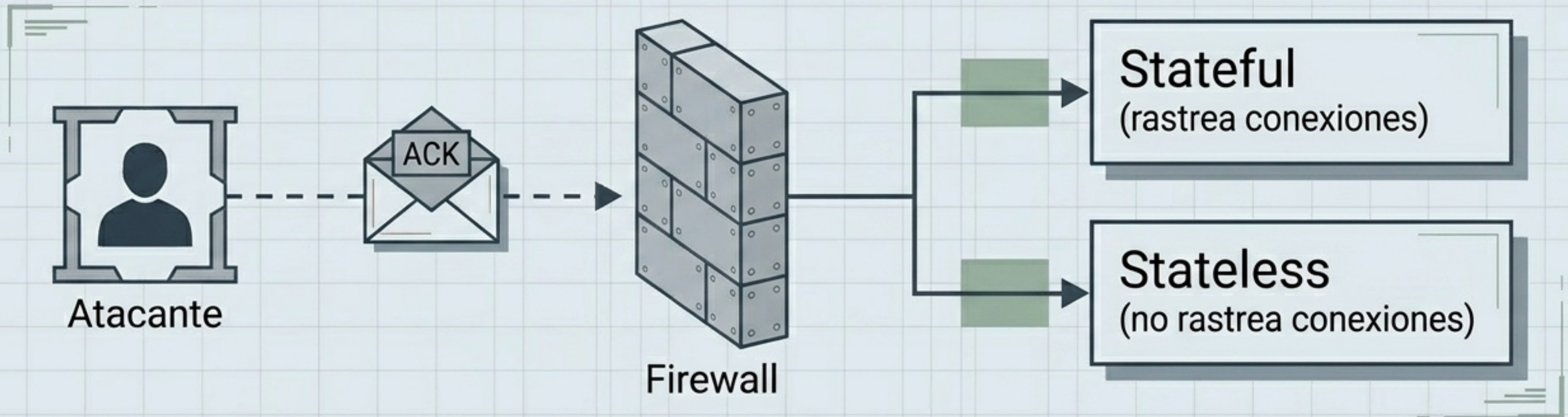
Completa el apretón de manos completo de 3 vías. Confiable, pero ruidoso (deja logs).

TCP SYN

Escaneo sigiloso predeterminado. Envía un paquete SYN, espera el SYN-ACK, y rompe la conexión antes de que se registre en la aplicación destino.

Evación y Mapeo: Escaneo TCP ACK

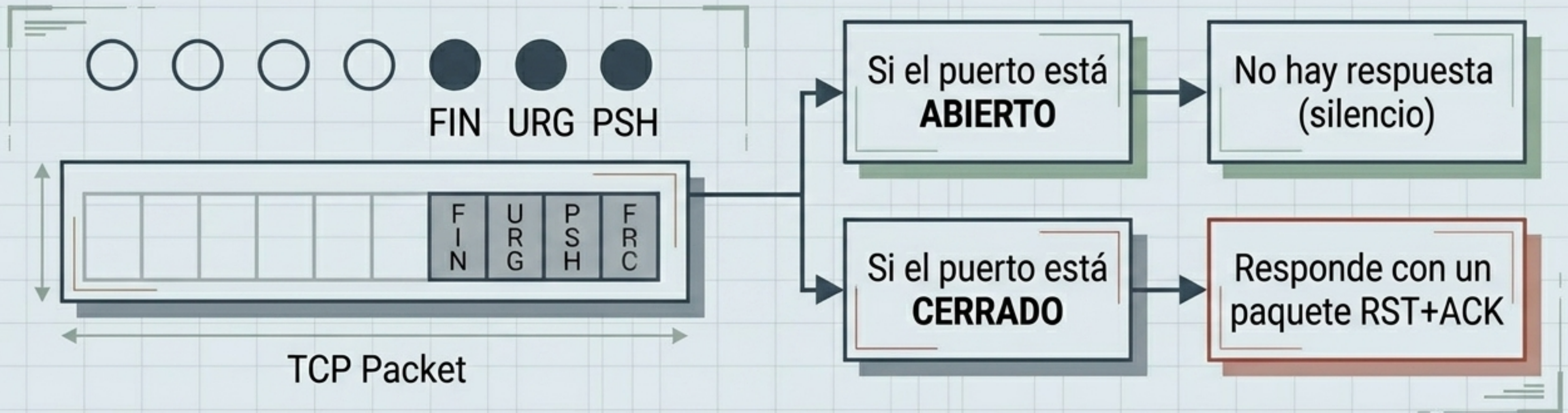
Esta técnica no intenta determinar si un servicio está abierto o cerrado. Su único objetivo es analizar la armadura de la red.



Objetivo: Determinar el tipo de cortafuegos. Los puertos suelen responder como 'No Filtrados'.

Técnicas Stealth I: Escaneo TCP X-MAS

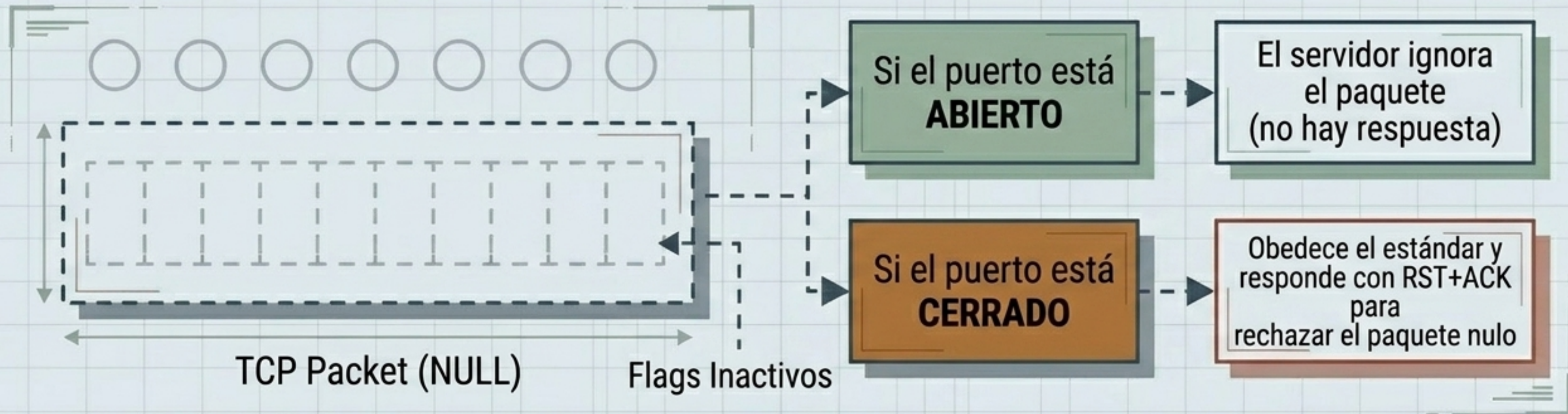
Una técnica de evasión clásica diseñada para eludir firewalls que solo bloquean paquetes SYN entrantes.



Nota Crítica: Los sistemas Windows modernos no responden a esta técnica según el estándar original.

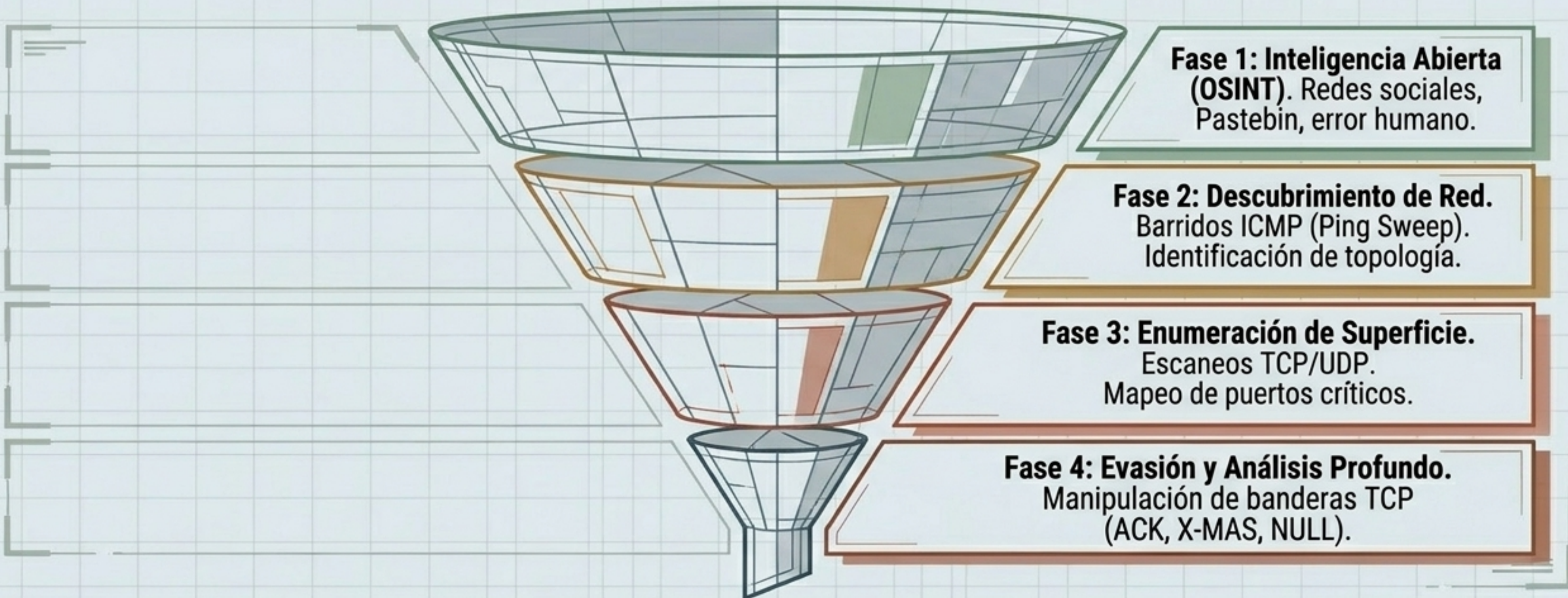
Técnicas Stealth II: Escaneo TCP NULL

La manipulación opuesta al escaneo X-MAS. Se basa en una ambigüedad del protocolo TCP enviando un paquete sin bits de control.



Nota Técnica: Esta técnica explota cómo algunos sistemas implementan la ausencia de banderas TCP.

El Ecosistema del Information Gathering



Conclusión: Un auditor experto no lanza un ataque a ciegas; desciende metódicamente por este embudo hasta que la vulnerabilidad se revela por sí sola.